

---

## Informe de Pentesting

### Actividad A08 — Hacking Ético

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

---

Seguridad Aplicada a Sistemas de Información  
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño Docente:  
Ing. Rodrigo Atilio Elgueta

**Estudiante:** Julian Greco  
**Username TryHackMe:** juliangreco

#### Contents

|          |                                         |           |
|----------|-----------------------------------------|-----------|
| <b>1</b> | <b>Resumen ejecutivo</b>                | <b>2</b>  |
| <b>2</b> | <b>Datos generales</b>                  | <b>2</b>  |
| <b>3</b> | <b>Pre-pentesting</b>                   | <b>2</b>  |
| <b>4</b> | <b>Durante: Hallazgos por fase</b>      | <b>3</b>  |
| <b>5</b> | <b>Resumen ejecutivo de hallazgos</b>   | <b>14</b> |
| <b>6</b> | <b>Post-pentesting: Recomendaciones</b> | <b>15</b> |
| <b>7</b> | <b>Protocolo de Contingencia</b>        | <b>16</b> |
| <b>8</b> | <b>Conclusiones</b>                     | <b>16</b> |
| <b>9</b> | <b>Anexos</b>                           | <b>17</b> |

## 1. Resumen ejecutivo

Entre el 06/10/2026 y el 08/10/2026 se realizó una evaluación de penetración sobre tres entornos de laboratorio de TryHackMe (*Pentesting Fundamentals*, *Basic Pentesting* y *RootMe*), en el marco de la Actividad A08 de la cátedra Seguridad Aplicada a Sistemas de Información. Se identificaron **8 hallazgos** (4 críticos, 2 altos y 2 medios), que en conjunto conforman una cadena de ataque completa: desde la enumeración inicial de usuarios y la filtración de información sensible, pasando por un acceso inicial mediante contraseña débil, hasta la escalada total de privilegios a root en ambas máquinas Linux evaluadas. Se documenta además una vulnerabilidad crítica conocida (Ghostcat, CVE-2020-1938) presente en la superficie expuesta pero no explotada por no ser necesaria para los objetivos de la sala. Las causas raíz predominantes fueron errores de configuración y manejo inseguro de credenciales, más que vulnerabilidades de software sin parche disponible, por lo que las recomendaciones de la Sección 6 priorizan medidas de *hardening* y gestión de credenciales por sobre el parcheo puntual.

## 2. Datos generales

| Campo                      | Valor                                                              |
|----------------------------|--------------------------------------------------------------------|
| Cliente                    | INSECUR S.A.                                                       |
| Contratista (alumno/a)     | Julian Greco                                                       |
| DNI                        | 39.169.367                                                         |
| Username TryHackMe         | juliangreco                                                        |
| Email institucional        | <a href="mailto:grecojulian@uch.edu.ar">grecojulian@uch.edu.ar</a> |
| Sala de elección (Nivel 2) | RootMe                                                             |
| Branch en GitHub           | julian-greco                                                       |
| Fecha de inicio            | 06/10/2026                                                         |
| Fecha de cierre            | 08/10/2026                                                         |

### 3. Pre-pentesting

#### Alcance del trabajo

El alcance de esta intervención comprende únicamente los entornos de laboratorio provistos por la plataforma TryHackMe, correspondientes a las siguientes salas:

**Pentesting Fundamentals** (núcleo obligatorio): entorno simulado de la empresa ficticia ACME.

**Basic Pentesting** (núcleo obligatorio): máquina Linux con servicios SSH, HTTP y Samba (*Web App Test*).

**RootMe** (sala de elección, Nivel 2): máquina Linux con servicio web vulnerable (*HackIT - Home*).

Quedan expresamente **excluidos** del alcance: cualquier sistema fuera de las máquinas asignadas por TryHackMe para cada sala, la infraestructura real de INSECUR S.A. (inexistente, utilizada solo como marco narrativo), y cualquier sistema de terceros accesible desde la red de laboratorio.

#### Reglas de Enfrentamiento (ROE)

**Horarios:** las pruebas se realizaron exclusivamente dentro de las sesiones de laboratorio habilitadas por la cátedra, con la máquina virtual (VPN de TryHackMe) activa y el tiempo de vida de cada *lab machine* controlado por la propia plataforma.

**Técnicas prohibidas:** no se realizaron ataques de denegación de servicio (DoS) sostenidos, fuerza bruta indiscriminada fuera de lo estrictamente necesario para la sala, ni intentos de pivoteo hacia redes fuera del rango asignado por TryHackMe.

**Límites de tráfico:** los escaneos de puertos se realizaron con nmap en modo moderado (-T4), evitando saturar el enlace VPN; la enumeración de directorios web se acotó a diccionarios estándar (dirb/common.txt).

**Notificación ante incidentes:** cualquier comportamiento anómalo del laboratorio (caída de la VPN, máquina inaccesible, reinicio inesperado) se gestionó reconectando según las herramientas provistas por TryHackMe, sin requerir escalado al docente en esta instancia.

#### Autorización

Declaro que las actividades descriptas en este informe se realizaron únicamente sobre los entornos de laboratorio provistos por TryHackMe, bajo autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH), en el marco de la Actividad A08. Ninguna técnica aquí documentada fue aplicada contra sistemas reales o de terceros sin autorización.

#### Metodología utilizada

Se siguió un enfoque alineado a **PTES (Penetration Testing Execution Standard)**, adaptado a las cuatro fases propuestas por la guía de cátedra: *Reconocimiento*, *Escaneo*, *Explotación* y *Post-explotación*. Se eligió PTES por ser un estándar ampliamente adoptado en la industria, con un flujo de trabajo claro y iterativo que facilita la trazabilidad de cada hallazgo desde su detección hasta su remediación, y porque se corresponde directamente con la estructura de evidencias solicitada por la cátedra (carpetas reconocimiento/, escaneo/, explotacion/, post/).

## SALA BASIC PENTESTING

## 4. Durante: Hallazgos por fase

## H-01 — Enumeración de puertos, servicios y versiones mediante Nmap

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Fase                          | <input checked="" type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                            |
| Descripción                   | Durante el escaneo de la sala <b>Basic Pentesting</b> , se utilizó Nmap para identificar los puertos TCP accesibles en la máquina objetivo, así como los servicios y versiones asociados. El análisis permitió determinar la superficie de ataque disponible y detectar servicios que posteriormente fueron utilizados para continuar con las tareas de enumeración. La información obtenida sirvió como punto de partida para seleccionar herramientas y técnicas específicas según cada servicio detectado. |
| Componente afectado           | Servicios de red expuestos en la máquina objetivo                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Categoría (OWASP / CWE)       | CWE-200: Exposure of Sensitive Information to an Unauthorized Actor                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| CVE (si aplica)               | No aplica directamente.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input checked="" type="checkbox"/> Medio <input type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                        |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Reconocimiento\1_H-01_NMAP _                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Herramienta utilizada         | Nmap                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input type="checkbox"/> Integridad <input type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                              |
| Salvaguarda propuesta         | Reducir la superficie de ataque manteniendo expuestos únicamente los servicios estrictamente necesarios; implementar reglas de firewall para restringir el acceso según origen y necesidad; deshabilitar servicios innecesarios; mantener actualizados los servicios y revisar periódicamente los puertos accesibles desde la red.                                                                                                                                                                            |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                         |

**H-02 — Enumeración de usuarios vía sesión nula SMB (RID cycling)**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-02                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Fase                          | <input type="checkbox"/> Reconocimiento <input checked="" type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                |
| Descripción                   | Durante la enumeración de la sala Basic Pentesting, <code>enum4linux</code> permitió identificar usuarios locales mediante una sesión nula SMB y RID cycling, sin necesidad de credenciales. Se identificaron las cuentas <code>kay</code> , <code>jan</code> y <code>ubuntu</code> . Esta exposición de información amplió la superficie de ataque y permitió orientar posteriormente ataques dirigidos contra usuarios válidos. |
| Componente afectado           | Servicio Samba (SMB)                                                                                                                                                                                                                                                                                                                                                                                                              |
| Categoría (OWASP / CWE)       | CWE-200: Exposure of Sensitive Information to an Unauthorized Actor                                                                                                                                                                                                                                                                                                                                                               |
| CVE (si aplica)               | No aplica (error de configuración)                                                                                                                                                                                                                                                                                                                                                                                                |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input checked="" type="checkbox"/> Medio <input type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                            |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Escaneo\1_H-02_enum4linux _ _                                                                                                                                                                                                                                                                                                                                                                         |
| Herramienta utilizada         | enum4linux                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input type="checkbox"/> Integridad <input type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                  |
| Salvaguarda propuesta         | Deshabilitar sesiones nulas/anónimas en Samba ( <code>restrict anonymous</code> ); exigir autenticación para listar usuarios y recursos compartidos; segmentar el servicio SMB de redes no confiables.                                                                                                                                                                                                                            |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                             |

**H-03 — Divulgación de información sensible en directorio /development/ expuesto**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-03                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Fase                          | <input type="checkbox"/> Reconocimiento <input checked="" type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Descripción                   | Durante la enumeración de directorios web con Gobuster se identificó el directorio /development/, accesible sin autenticación. En su interior se encontraron los archivos dev.txt y j.txt, que contenían información interna del equipo de desarrollo. Entre los datos expuestos se identificó la versión de software utilizada, <b>Struts 2.5.12</b> , y una comunicación interna indicando que la contraseña del usuario jan había podido ser crackeada durante una auditoría del archivo /etc/shadow. Esta información permitió identificar una posible debilidad en las credenciales y orientar etapas posteriores del pentesting. |
| Componente afectado           | Servidor web Apache — directorio /development/                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Categoría (OWASP / CWE)       | CWE-200: Exposure of Sensitive Information to an Unauthorized Actor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| CVE (si aplica)               | No aplica directamente                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input checked="" type="checkbox"/> Medio <input type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Escaneo\1_H-03_gobuster                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Herramienta utilizada         | Gobuster con wordlist dirb/common.txt y navegador web                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input type="checkbox"/> Integridad <input type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Salvaguarda propuesta         | Eliminar archivos de desarrollo y comunicaciones internas del entorno expuesto; restringir el acceso a directorios que no deban ser públicos mediante autenticación o reglas del servidor web; evitar almacenar información sensible en el directorio raíz del servidor; incorporar revisiones de contenido expuesto antes del despliegue a producción.                                                                                                                                                                                                                                                                                |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |

**H-04 — Contraseña SSH débil del usuario jan**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-04                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input checked="" type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                       |
| Descripción                   | A partir del usuario <code>jan</code> identificado previamente en H-02, se realizó un ataque de diccionario dirigido contra el servicio SSH utilizando Hydra y la wordlist <code>rockyou.txt</code> . La contraseña fue identificada en un período reducido de tiempo, confirmando la debilidad de credenciales anticipada por la información expuesta en H-02. Las credenciales obtenidas permitieron acceder mediante SSH al sistema objetivo, constituyendo el vector de acceso inicial a la máquina. |
| Componente afectado           | Servicio SSH (OpenSSH) — cuenta jan                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Categoría (OWASP / CWE)       | CWE-521: Weak Password Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| CVE (si aplica)               | No aplica                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input checked="" type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                   |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Explotacion\1_H-04_hydra - - - - -                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Herramienta utilizada         | hydra, rockyou.txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                              |
| Salvaguarda propuesta         | Implementar una política de contraseñas robustas que contemple longitud mínima y resistencia frente a ataques de diccionario; limitar los intentos fallidos de autenticación mediante mecanismos como <code>fail2ban</code> ; restringir el acceso SSH a redes autorizadas y priorizar autenticación mediante claves públicas, deshabilitando la autenticación por contraseña cuando sea posible.                                                                                                        |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                    |

**H-05 — Clave SSH privada con permisos de lectura pública**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-05                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input checked="" type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Descripción                   | Durante la enumeración local posterior al acceso inicial, LinPEAS permitió identificar que la clave privada SSH del usuario <code>kay</code> , ubicada en <code>/home/kay/.ssh/id_rsa</code> , poseía permisos <code>-rw-r--r--</code> , permitiendo su lectura por otros usuarios locales del sistema. Aunque la clave estaba protegida mediante passphrase, esta pudo ser recuperada mediante un ataque de diccionario fuera de línea utilizando <code>ssh2john</code> y John the Ripper. La clave obtenida permitió autenticarse como el usuario <code>kay</code> , ampliando el nivel de acceso disponible en el sistema. |
| Componente afectado           | Archivo de clave privada SSH <code>/home/kay/.ssh/id_rsa</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Categoría (OWASP / CWE)       | CWE-522: Insufficiently Protected Credentials                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| CVE (si aplica)               | No aplica — error de configuración y permisos                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input checked="" type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Post\1_H-05_ssh-jan<br>evidencias\Basic Pentesting\Post\1_H-05_ssh-jan-2<br>evidencias\Basic Pentesting\Post\1_H-05_clave-privada-kay<br>evidencias\Basic Pentesting\Post\1_H-05_passphrase-kay                                                                                                                                                                                                                                                                                                                                                                                                   |
| Herramienta utilizada         | LinPEAS, <code>ssh2john</code> y John the Ripper; diccionario <code>rockyou.txt</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input type="checkbox"/> Integridad <input type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Salvaguarda propuesta         | Restringir los permisos de las claves privadas SSH mediante <code>chmod 600 ~/.ssh/id_rsa</code> ; revocar y reemplazar inmediatamente cualquier clave comprometida; utilizar passphrases robustas y resistentes a ataques de diccionario; revisar periódicamente los permisos de archivos sensibles y aplicar el principio de mínimo privilegio sobre los directorios personales.                                                                                                                                                                                                                                            |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |

**H-06 — Contraseña de sudo almacenada en archivo de backup legible**

I

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | H-06                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input checked="" type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                          |
| Descripción                   | Una vez autenticado como el usuario <code>kay</code> , se identificó en su directorio personal el archivo <code>/home/kay/pass.bak</code> , el cual contenía una contraseña almacenada en texto plano. Al verificar los privilegios del usuario mediante <code>sudo -l</code> , se comprobó que <code>kay</code> podía ejecutar comandos con privilegios elevados. La credencial expuesta permitió autenticarse mediante <code>sudo</code> y obtener acceso como usuario <code>root</code> , logrando una escalada completa de privilegios. |
| Componente afectado           | Archivo <code>/home/kay/pass.bak</code> y gestión de credenciales del usuario <code>kay</code>                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Categoría (OWASP / CWE)       | CWE-312: Cleartext Storage of Sensitive Information                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| CVE (si aplica)               | No aplica                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto <input checked="" type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                      |
| Evidencia (captura / comando) | evidencias\Basic Pentesting\Post\ 1_H-06_ssh-kay                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Herramienta utilizada         | Shell de Linux, <code>cat</code> , <code>sudo -l</code> y <code>sudo</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                      |
| Salvaguarda propuesta         | Eliminar archivos que contengan credenciales en texto plano; cambiar inmediatamente cualquier contraseña expuesta; evitar almacenar credenciales en archivos de backup o directorios personales; restringir los permisos sobre información sensible y aplicar el principio de mínimo privilegio a las cuentas con acceso mediante <code>sudo</code> .                                                                                                                                                                                       |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                       |

## SALA BASIC ROOTME

## I-01 — Servicios de red expuestos identificados mediante Nmap

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |   |   |   |   |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---|---|---|---|
| ID del hallazgo               | I-01                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |   |   |   |   |
| Fase                          | <input type="checkbox"/> Reconocimiento <input checked="" type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                              |   |   |   |   |
| Descripción                   | Durante el escaneo inicial de la máquina objetivo mediante Nmap se identificaron dos servicios TCP accesibles desde la red. El puerto 22/tcp correspondía al servicio SSH ejecutando <b>OpenSSH 8.2p1 Ubuntu</b> , mientras que el puerto 80/tcp exponía un servidor web <b>Apache httpd 2.4.41 (Ubuntu)</b> . La identificación de estos servicios y sus versiones permitió determinar la superficie de ataque inicial y orientar las tareas posteriores de enumeración, principalmente sobre el servicio web. |   |   |   |   |
| Componente afectado           | Servicios de red SSH (22/tcp) y HTTP (80/tcp)                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |   |   |   |   |
| Categoría (OWASP / CWE)       | CWE-200: Exposure of Sensitive Information to an Unauthorized Actor                                                                                                                                                                                                                                                                                                                                                                                                                                             |   |   |   |   |
| CVE (si aplica)               | No aplica directamente.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |   |   |   |   |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input checked="" type="checkbox"/> Medio <input type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                          | - | - | - | - |
| Evidencia (captura / comando) | evidencias\RootMe\Reconocimiento\2-I-01-NMAP                                                                                                                                                                                                                                                                                                                                                                                                                                                                    | - | - | - | - |
| Herramienta utilizada         | Nmap                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | - | - | - | - |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                          |   |   |   |   |
| Salvaguarda propuesta         | Mantener habilitados únicamente los servicios estrictamente necesarios; restringir mediante firewall el acceso a servicios administrativos como SSH; mantener actualizados OpenSSH y Apache; revisar periódicamente los puertos expuestos y reducir la información de versiones divulgada por los servicios cuando sea posible.                                                                                                                                                                                 |   |   |   |   |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                           |   |   |   |   |

**I-02 — Enumeración de directorios web expuestos**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | I-02                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Fase                          | <input type="checkbox"/> Reconocimiento <input checked="" type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Descripción                   | Durante la enumeración del servidor web mediante Gobuster se identificaron varios recursos accesibles públicamente, entre ellos los directorios <code>/panel/</code> y <code>/uploads/</code> , además de <code>/css/</code> y <code>/js/</code> . La exposición de estos directorios amplía la superficie de ataque y permite identificar funcionalidades internas del sitio que pueden ser analizadas en etapas posteriores. En particular, la existencia de un directorio <code>/panel/</code> sugiere una interfaz de administración o carga de archivos, mientras que <code>/uploads/</code> podría contener archivos almacenados por la aplicación. |
| Componente afectado           | Servidor web Apache — directorios <code>/panel/</code> y <code>/uploads/</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Categoría (OWASP / CWE)       | CWE-200: Exposure of Sensitive Information to an Unauthorized Actor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| CVE (si aplica)               | No aplica                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input checked="" type="checkbox"/> Medio <input type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Evidencia (captura / comando) | evidencias\RootMe\Escaneo\2_I-02_gobuster_ - - - -                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Herramienta utilizada         | Gobuster — wordlist<br><code>/usr/share/wordlists/dirb/common.txt</code>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Salvaguarda propuesta         | Restringir el acceso a directorios que no deban ser públicos; proteger interfaces administrativas mediante autenticación; evitar la exposición de rutas internas innecesarias; configurar adecuadamente permisos del servidor web y revisar periódicamente los recursos accesibles desde el exterior.                                                                                                                                                                                                                                                                                                                                                     |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

**I-03 — Carga de archivos con validación insuficiente de tipo**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | I-03                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input checked="" type="checkbox"/> Explotación <input type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Descripción                   | Durante la evaluación de la sala <b>RootMe</b> , se identificó en <code>/panel/</code> un formulario de carga de archivos accesible sin autenticación. Un primer intento de cargar una web shell con extensión <code>.php</code> fue rechazado por un filtro basado en blacklist. Sin embargo, al renombrar el mismo archivo con extensión <code>.phtml</code> , la carga fue aceptada y el servidor interpretó el archivo como código PHP ejecutable. Esto permitió obtener <b>ejecución remota de código (RCE)</b> y establecer una reverse shell con el usuario <code>www-data</code> , demostrando que la validación del tipo de archivo era insuficiente. |
| Componente afectado           | Formulario de carga en <code>/panel/</code> — servidor web Apache                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Categoría (OWASP / CWE)       | CWE-434: Unrestricted Upload of File with Dangerous Type                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| CVE (si aplica)               | No aplica                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto <input checked="" type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Evidencia (captura / comando) | evidencias\RootMe\Explotacion\2_I-03_error-upload<br>evidencias\RootMe\Explotacion\2_I-03_archivo-phtml<br>evidencias\RootMe\Explotacion\2_I-03_archivo-uploaded<br>evidencias\RootMe\Explotacion\2_I-03_acceso-cmd<br>evidencias\RootMe\Explotacion\2_I-03_ingreso-ssh                                                                                                                                                                                                                                                                                                                                                                                        |
| Herramienta utilizada         | Navegador web, web shell PHP y Netcat. Gobuster fue utilizado previamente para descubrir <code>/panel/</code> .                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Salvaguarda propuesta         | Implementar una whitelist estricta de extensiones permitidas; validar el tipo MIME real y el contenido del archivo; almacenar los archivos subidos fuera del <code>document root</code> o en ubicaciones sin permisos de ejecución; renombrar los archivos del lado del servidor; restringir el acceso al formulario mediante autenticación; y aplicar controles adicionales de tamaño y contenido.                                                                                                                                                                                                                                                            |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |

**I-04 — Obtención de shell interactiva mediante Python**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                  |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | I-04                                                                                                                                                                                                                                                                                                                                                   |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input checked="" type="checkbox"/> Post-explotación                                                                                                                                                                                     |
| Descripción                   | Tras obtener una reverse shell bajo el contexto del usuario <code>www-data</code> , se utilizó el intérprete Python disponible en el sistema para generar una shell Bash interactiva. Esta acción permitió mejorar la funcionalidad de la sesión remota obtenida previamente y facilitar la ejecución de comandos durante la fase de post-explotación. |
| Componente afectado           | Sistema operativo / entorno de ejecución del servidor                                                                                                                                                                                                                                                                                                  |
| Categoría (OWASP / CWE)       | No aplica como vulnerabilidad independiente. Técnica de post-explotación.                                                                                                                                                                                                                                                                              |
| CVE (si aplica)               | No aplica                                                                                                                                                                                                                                                                                                                                              |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto <input checked="" type="checkbox"/> Crítico                                                                                                                                                                                                                 |
| Evidencia (captura / comando) | evidencias\RootMe\Post\2_I-04_python-bash -                                                                                                                                                                                                                                                                                                            |
| Herramienta utilizada         | Python / Bash                                                                                                                                                                                                                                                                                                                                          |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                 |
| Salvaguarda propuesta         | Restringir la ejecución de intérpretes y herramientas innecesarias según el principio de mínimo privilegio; utilizar mecanismos de control de ejecución y limitar las capacidades del usuario del servidor web.                                                                                                                                        |
| Riesgo residual tras aplicar  | <input checked="" type="checkbox"/> Bajo <input type="checkbox"/> Medio <input type="checkbox"/> Alto                                                                                                                                                                                                                                                  |

**I-05 — Escalada de privilegios mediante Python con SUID**

| Campo                         | Valor                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ID del hallazgo               | I-05                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Fase                          | <input type="checkbox"/> Reconocimiento <input type="checkbox"/> Escaneo <input type="checkbox"/> Explotación <input checked="" type="checkbox"/> Post-explotación                                                                                                                                                                                                                                                                                                                                                                                                    |
| Descripción                   | Tras obtener una reverse shell bajo el contexto del usuario www-data, se realizó una enumeración de archivos con permiso SUID para identificar posibles vectores de escalada de privilegios. Se identificó la disponibilidad de un intérprete Python con privilegios elevados. La ejecución de Python permitió invocar /bin/sh utilizando la opción -p, preservando los privilegios efectivos asociados al proceso. Como resultado, la sesión pasó del contexto de www-data al usuario root, obteniéndose una shell con privilegios administrativos sobre el sistema. |
| Componente afectado           | Sistema operativo — permisos SUID asignados a un intérprete Python                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Categoría (OWASP / CWE)       | CWE-732: Incorrect Permission Assignment for Critical Resource                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| CVE (si aplica)               | No aplica — configuración/permisos inseguros del sistema                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| CVSS estimado                 | <input type="checkbox"/> Bajo <input type="checkbox"/> Medio <input checked="" type="checkbox"/> Alto <input type="checkbox"/> Crítico                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Evidencia (captura / comando) | evidencias\RootMe\Post\2_I-05_user-root -<br>evidencias\RootMe\Post\2_I-05_root-txt                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Herramienta utilizada         | Shell, Python y comandos nativos de Linux                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Impacto en la Tríada CIA      | <input checked="" type="checkbox"/> Confidencialidad <input checked="" type="checkbox"/> Integridad <input checked="" type="checkbox"/> Disponibilidad                                                                                                                                                                                                                                                                                                                                                                                                                |
| Salvaguarda propuesta         | Eliminar el bit SUID de Python cuando no sea estrictamente necesario; revisar periódicamente los binarios con SUID/SGID; aplicar el principio de mínimo privilegio; evitar que intérpretes de lenguajes de programación posean privilegios SUID; y establecer controles de integridad y permisos sobre binarios críticos.                                                                                                                                                                                                                                             |

Riesgo residual tras aplicar ☒ Bajo ☐ Medio ☐ Alto

## 5. Resumen ejecutivo de hallazgos

| Severidad    | Cantidad  | ID de hallazgos                  |
|--------------|-----------|----------------------------------|
| Crítico      | 3         | H-06, I-03, I-04                 |
| Alto         | 3         | H-04, H-05, I-05                 |
| Medio        | 5         | H-01, H-02, H-03, I-01, I-02     |
| Bajo         | 0         | —                                |
| <b>Total</b> | <b>11</b> | <b>H-01 a H-06 + I-01 a I-05</b> |

### Lectura general

La mayoría de los hallazgos corresponden a errores de configuración, controles de seguridad insuficientes y manejo deficiente de credenciales, más que a vulnerabilidades con CVE propio. En Basic Pentesting se identificó una cadena de compromiso que comenzó con la enumeración SMB (H-02), continuó con la exposición de información en /development/ (H-03), permitió obtener acceso mediante una contraseña débil (H-04), acceder como kay mediante una clave SSH expuesta (H-05) y finalmente escalar a root mediante credenciales almacenadas en texto plano (H-06).

En RootMe, una carga de archivos insuficientemente validada (I-03) permitió obtener RCE y una reverse shell como www-data, seguida de una escalada de privilegios mediante Python con SUID (I-05). En conjunto, los resultados demuestran cómo varias configuraciones inseguras y debilidades de credenciales pueden combinarse para lograr el compromiso completo de un sistema.

## 6. Post-pentesting: Recomendaciones

### Recomendaciones técnicas (parches y configuraciones)

1. **(Prioridad crítica)** Eliminar archivos que contengan credenciales en texto plano y cambiar inmediatamente las contraseñas expuestas (H-06).
2. **(Prioridad crítica)** Reemplazar la blacklist de extensiones por una whitelist estricta y evitar la ejecución de archivos cargados (I-03).
3. **(Prioridad alta)** Eliminar bits SUID innecesarios, especialmente en intérpretes de propósito general como Python (I-05).
4. **(Prioridad alta)** Implementar contraseñas robustas, limitar intentos de autenticación y priorizar claves públicas para SSH (H-04).
5. **(Prioridad alta)** Restringir los permisos de las claves privadas SSH a 600 y reemplazar cualquier clave que haya sido expuesta (H-05).
6. **(Prioridad media)** Deshabilitar sesiones nulas o anónimas en Samba y restringir el acceso al servicio (H-02).
7. **(Prioridad media)** Eliminar archivos y directorios de desarrollo o información interna accesibles públicamente (H-03).
8. **(Prioridad media)** Reducir la superficie de ataque manteniendo expuestos únicamente los servicios necesarios y restringiendo SSH mediante firewall (H-01, I-01).
9. **(Prioridad media)** Restringir el acceso a /panel/ y /uploads/ y proteger cualquier funcionalidad administrativa mediante autenticación (I-02).
10. **(Prioridad baja/media)** Mantener Apache, OpenSSH, kernel y demás componentes actualizados y soportados expuesto a la red.
11. Revisar periódicamente permisos, servicios expuestos, credenciales almacenadas y archivos con permisos SUID/SGID.

### Recomendaciones administrativas (políticas y procesos)

1. Establecer una política formal de gestión de credenciales que prohíba explícitamente su almacenamiento en texto plano, con rotación periódica obligatoria.
2. Incorporar capacitación para el equipo de desarrollo sobre validación segura de cargas de archivos (OWASP Top 10, categorías A04 y A05).
3. Definir un proceso trimestral de revisión de permisos de archivos y binarios SUID/SGID (*hardening checklist*).
4. Implementar un proceso formal de gestión de vulnerabilidades, con ventanas de parcheo definidas según criticidad.

## 7. Protocolo de Contingencia

### Escenario de falla

Durante una prueba de carga de archivos sobre un formulario de subida como el identificado en H-06, un archivo malformado o un intento de explotación mal calibrado podría provocar un error fatal no controlado en el proceso de Apache/PHP, interrumpiendo la disponibilidad del servicio web de cara al cliente mientras dure la caída.

### Impacto sobre la continuidad del negocio

Se vería afectado el servicio web público de INSECUR S.A., impidiendo el acceso de clientes y empleados a los sistemas alojados en el servidor comprometido. Según la duración de la interrupción y la existencia (o no) de redundancia, el impacto podría oscilar entre 15 minutos de indisponibilidad parcial y varias horas de caída total si no existe un servidor espejo disponible.

### Plan de respuesta

1. **Activación:** un sistema de monitoreo activo (*healthchecks* HTTP periódicos) detecta la caída del servicio o códigos de error 5xx sostenidos y dispara una alerta automática al equipo de guardia.
2. **Contención:** en los primeros 15 minutos se aísla el servidor afectado de la red (regla de firewall o apagado de la interfaz), se detiene el proceso comprometido de Apache/PHP y se preservan los logs para análisis forense posterior.
3. **Recuperación:** se restaura el servicio desde un servidor espejo (*failover*) si existe, o se reinstala desde una imagen limpia versionada (Infraestructura como Código) reaplicando la configuración conocida y los últimos backups válidos.
4. **Comunicación:** se notifica de inmediato a la dirección de INSECUR S.A.; si se confirma una brecha con exposición de datos, se evalúa la notificación a clientes afectados y, de corresponder, a las autoridades competentes según la normativa de protección de datos vigente.
5. **Post-mortem:** se documenta la causa raíz, la línea de tiempo completa del incidente y las acciones tomadas; se actualizan los *runbooks* internos y las reglas de monitoreo para prevenir recurrencias.

### RTO y RPO estimados

**RTO** (Recovery Time Objective): 2 horas, considerando la restauración desde servidor espejo o imagen versionada.

**RPO** (Recovery Point Objective): 1 hora, asumiendo una frecuencia de backups horaria para los componentes críticos.

## 8. Conclusiones

La evaluación confirmó que tanto Basic Pentesting como RootMe pudieron comprometerse mediante cadenas de debilidades relacionadas principalmente con configuraciones inseguras, exposición de información y manejo deficiente de credenciales. En Basic Pentesting, la enumeración SMB y la información expuesta facilitaron el acceso inicial y posteriormente la escalada hasta root. En RootMe, una carga de archivos insuficientemente validada permitió obtener RCE y posteriormente escalar privilegios mediante un binario Python con SUID.

En conjunto, los resultados muestran que varias debilidades individuales de severidad moderada pueden combinarse para producir un compromiso completo del sistema. Por ello, se recomienda priorizar el hardening, la gestión segura de credenciales, el control de permisos y la reducción de la superficie de ataque.

## 9. Anexos

### Anexo A — Bitácora de comandos

Se adjuntan en la carpeta bitacora/RootMe los siguientes archivos:

nmap\_inicial.txt — Sala RootMe.

gobuster.txt — Sala RootMe

### Anexo B — Capturas de pantalla

Las evidencias se encuentran en la carpeta evidencias/ del branch, organizadas en subcarpetas por fase: reconocimiento/, escaneo/, explotacion/ y post/. Cada archivo sigue la convención <fase>\_<ID>.png, donde <ID> identifica la sala y el paso correspondiente (por ejemplo, RM-08 para el paso 8 de la sala RootMe).

### Anexo C — Hashes de credenciales obtenidas

| # | Formato | hallazgo_id | descripcion                                                                              | sha256_hash |
|---|---------|-------------|------------------------------------------------------------------------------------------|-------------|
| 1 | H-03    | password    | SSH inicial (jan)                                                                        | 9           |
| 2 |         |             | eb 6835 cc95 b 053818 b 660 bd 9 fc9 f092 a 0 b 30 cef89 c1 f0 f17 f469 d 5 caa 0 ae 617 |             |
| 3 | H-04    | passphrase  | clave SSH (kay)                                                                          | 873504      |
| 4 |         |             | f0103 a 88 d 762191 a 358 f4 aa 432 dbbcf8 af64 f19 dd 913 d 7 f8 f925191 a 08           |             |
|   | H-05    | password    | sudo (kay)                                                                               | 3           |
|   |         |             | ffd 53 ec80858 f9 ddcd 75 d 69102724 ab 1 bc1020855 fff924227 f618 c4 bfccf57            |             |

*Flags obtenidas (sala RootMe):* siguiendo el control de *hash de las flags* de la cátedra, se incluye el hash SHA-256 de cada flag en lugar de su texto plano, evitando exponer valores que circulan en writeups públicos:

| # | Formato  | flag | sha256_hash                                                                                    |
|---|----------|------|------------------------------------------------------------------------------------------------|
| 1 | user.txt | 8    |                                                                                                |
| 2 |          |      | c8 b99 b3 c6 b 7 a 61 eb 0399 dfab 5 b 59 c08126 f998305 c6 d 05 fa 44 e 0 cc76 cfad 5 b 0     |
| 3 | root.txt |      |                                                                                                |
|   |          |      | ec3 faf2 a 7 f12 f82 b 7 ab 07 a 19 ca 777232 b 3 f67 ba 2 c2160 e 43802 ee 102 a 6 a 9 a 85 c |

**Anexo D — Declaración ética firmada**

Declaro que todas las actividades descriptas en este informe se realizaron dentro del alcance autorizado, en entornos controlados (laboratorios de TryHackMe) y con fines exclusivamente académicos, en el marco de la Actividad A08 de la cátedra Seguridad Aplicada a Sistemas de Información.

*Julian Greco*

Firma del estudiante

08/10/2026

Fecha